

WebTerm/3270 Security Tools

Direct use and benefit, tool by tool

Prepared by Britley Hoff | October 03, 2026

Every tool below lives in one open source bridge and browser client, no desktop emulator, no separate scanner install. Connect to any TN3270(E) or TN5250 host (z/OS, z/VM, IBM i, z/TPF) through the bridge, unlock the Security panel, and run the tool against the live session. All of it is built FOR AUTHORIZED USE ONLY, on an engagement where you already have permission to test the target.

This sheet is a quick reference for explaining a tool on the spot: what it does, how you actually run it, and the one sentence that answers "so what." Full walkthroughs, screenshots, and tutorial write-ups live in the project's own DOCUMENTATION/webterm-security-tools-tutorial.md.

Platform key: z/OS (TSO/RACF/SDSF/DB2/CICS), IBM i (AS/400), z/VM, z/TPF, Cross (any protocol/session).

Cross-Protocol and Session-Level

- Field Map Overlay (Cross) - Highlights every field's attribute-byte boundaries and type on the live screen. Toggle it on any connected session. Shows at a glance which fields are protected, nondisplay, or numeric-only, the field map most pentest notes have to reconstruct by hand.
- Attribute Byte Inspector (Cross) - Decodes the raw FA byte for any field you click. Click a field after connecting. Confirms exactly what a field's protection, display, and MDT bits really are instead of guessing from how it looks.
- Color Reveal (Cross) - Forces every character to a visible color. One click. Exposes color-on-color hidden text, a real and still-used way to bury sensitive data in plain sight on a 3270 screen.
- Field Length Disclosure (Cross) - Reads MDT and buffer-address deltas to recover how many characters were typed into a masked field. Watch a password or other nondisplay field get filled in. Proves a "masked" field still leaks its length over the wire.
- Traffic Recorder / Replay Viewer (Cross) - Records the full session datastream and plays it back frame by frame. Record, then replay from the Traffic panel. Turns a live finding into a reproducible artifact you can hand to a client or revisit later.
- Session Viewer (Cross) - Logs every AID key sent and screen received, with CSV export. Open alongside any session. A plain-language audit trail of exactly what happened during a test.
- Wire Inspector + Anomaly/Brute-Force Correlator (Cross) - Decodes the raw 3270/5250 packet stream and automatically flags repeated-ENTER and same-userid retry patterns against real RACF message IDs. Open Wire Inspector during or after a session. Does the "was someone just locked out or brute-forced" read for you instead of scrolling a packet log by hand.
- Proxy Viewer (Cross) - Live bridge log stream with level filtering. Open during any session. Operational visibility into the bridge itself, useful when a tool's result looks wrong and you need to rule the bridge out.
- Export Screen (Cross) - Copies or downloads the current screen as text. One click. Fast, clean

evidence capture for a report.

- MITM Intercept (Cross) - Holds, edits, releases, or drops outbound AID records before they reach the host. Arm it, then interact with the session normally. Proves a man-in-the-middle position is real by actually altering live traffic, not just claiming the position exists.
- Credential Harvest Log (Cross) - Captures nondisplay-field content seen during MITM intercepts. Runs automatically while MITM Intercept is armed. Turns "I was in the middle of this session" into an actual list of what was typed.
- Screen Watch (Cross) - Alerts when a chosen string appears anywhere on screen. Set a pattern, leave it running. Passive detection for a specific condition without babysitting the screen.
- Session Broadcast (Cross) - Sends one keystroke to every open session at once. Open multiple tabs, type once. Drives the same input across several hosts in parallel, useful for multi-LPAR credential checks.
- Protocol Fuzzer (Cross) - Five modes: AID byte sweep, oversized field payloads, 3270 order injection, malformed screen-buffer addresses, and a z/TPF handshake/negotiation fuzzer. Pick a mode and a payload, send. Finds the input the host doesn't handle gracefully, crash, hang, or disconnect, before a real attacker does.
- TN3270E Negotiation Analyzer (Cross) - Surfaces TLS version, cipher suite, certificate detail, negotiated LU, and terminal model for every active session. Open it with any session connected. One place to catch plaintext sessions, weak ciphers, and expired or self-signed certs across everything you're connected to.
- VTAM-Operator Pool/Session Dashboard (Cross) - Groups active sessions by LPAR against a configured session-count threshold, and flags a shop-specific "pool full" reject message immediately. Configure a threshold once, refresh anytime. Catches session-pool exhaustion before it takes an LPAR down.
- In-Transit Monitor (Cross) - Flags unencrypted TN3270 sessions and shows the actual exposed screen content and IND\$FILE transfers in the clear. Connect without TLS to see it fire. The clearest way to show a client what unencrypted mainframe traffic actually exposes.
- Passive ESM Fingerprint (Cross) - Identifies RACF, ACF2, or Top Secret purely from message IDs and banners already on screen, sends nothing to the host. Just connect and sign on. Zero-footprint recon: know which security manager you're dealing with before running anything active.
- SSH No-Credential Access Checker (Cross, SSH) - For z/TPF and other IBM ported-OpenSSH targets: one attempt at 'none'-method auth, one attempt at an empty password, only if the target actually offers it. Enter a host, port, and username, run the check. Catches two specific, real misconfigurations without ever running a brute-force sweep.

z/OS: TSO, RACF, SDSF, DB2, CICS

- RACF Probe - Sweeps a credential wordlist against a logon screen (TSO, z/VM, CICS, z/TPF, or IBM i), with an optional "keep going" enumeration mode. Navigate to a logon screen, load or type a wordlist, run. The classic default-credential check, automated and classified (success, failure, lockout, enumerated) instead of typed by hand one at a time.

- RACF Settings Analyzer - Reads global RACF options straight from TSO READY. Run from READY. Flags weak system-wide policy without needing special access.
- RACF User/Group Enumerator - Enumerates users and group membership. Run from READY. Builds the account and privilege map an engagement report needs, fast.
- Dataset Recon Scanner - Discovers datasets and flags access-control gaps. Run from READY. Surfaces exposed or under-protected datasets far faster than a manual LISTDSD sweep.
- Encryption Audit Scanner - Checks specific datasets for DFSMS at-rest encryption via LISTCAT. Feed it names from the recon scan, or type your own. Confirms whether "sensitive" data is actually encrypted at rest, not just access-controlled.
- VTAM Applid Enumerator - Sweeps a non-destructive display command against a wordlist of APPLIDs. Load or type a wordlist, run. Maps what's reachable on VTAM without the connection-per-guess cost of a real session-transfer sweep.
- APF Library Scanner - Enumerates every APF-authorized library and checks each for a RACF profile. Run from READY. A missing or weak profile on an APF library is a direct path to privilege escalation; this finds it in seconds.
- APF Writability Checker - Actually attempts a write against every APF library the scanner above found. Run right after the scanner. Proves exploitability instead of inferring it from a missing profile alone.
- PARMLIB Access Check - Tests read access to named SYS1.PARMLIB members. Load defaults or list your own members, run. A readable PARMLIB member exposes system configuration an attacker shouldn't get to read.
- SDSF Job Parser - Parses visible jobs on an SDSF ST/DA panel and flags system STCs visible from your privilege level. Navigate to SDSF, refresh. Fast read on what you can see relative to what you should be able to see.
- SDSF Job Output Harvester - Actively types a command for every job on the list and reads back the real per-job output. Run from an SDSF job list. Catches a non-zero return code or a sensitive keyword in job output, not just list-level status.
- STC Profile Scanner - Checks each started task's RACF STARTED-class profile. Run from TSO READY. A started task with no profile runs under the default user, a common, easy-to-miss gap.
- DB2 Subsystem Scanner - Enumerates DB2 subsystems. Run from TSO READY. Maps what DB2 is actually present before targeting the next two tools.
- RACF-DB2 Authority Scan - Checks RACF authority over DB2 resources. Run from TSO READY. Finds where DB2 access control and RACF disagree.
- DB2 Connection Permission Probe - Analyzes connection-level DB2 permissions. Run from TSO READY. Confirms who can actually connect, not just who's supposed to be able to.
- CICS Transaction Scanner - Probes transaction IDs from a wordlist at a CICS clear screen. Clear the screen, load or type a wordlist, run. A "not authorized" response still confirms a transaction exists, mapping the real transaction inventory even without access to any of them.
- Cross-Session Buffer Bleed - Detects a pooled LU's old screen content surviving into the next session before the fresh Erase/Write. Set an LU name, connect, disconnect, reconnect with the same LU name

within about 90 seconds. A genuinely dangerous VTAM pooling bug, proven live.

IBM i (AS/400)

- System Value Security Analyzer - Reads system security values (QSECURITY, password rules, and more). Sign on, stop at a menu, run. One read, full picture of system-wide posture.
- User Profile & Special-Authority Enumerator - Lists user profiles and their special authorities (ALLOBJ, SECADM, and others). Run from a menu. Finds who actually has the keys to the system, not just who's supposed to.
- Shipped Profile Audit - Drills every IBM-supplied Q profile against the real reference list and flags anything non-standard or still carrying a default password. Run from a menu. Catches both a forgotten default password and a blend-in decoy profile planted to look standard.
- Object / PUBLIC Authority Scanner - Scans objects for PUBLIC authority exposure. Run from a menu. The IBM i analog of a world-writable file check.
- Network Attributes Analyzer - Reads system network attributes. Run from a menu. Flags risky network-level configuration most audits skip.
- Job Description PrivEsc Scanner - Checks job descriptions for a privilege-escalation path, a job running under a more privileged profile than the one submitting it. Run from a menu. A classic, quiet IBM i escalation vector that a normal profile audit misses.
- Authorization List Scanner - Enumerates authorization lists and their members. Run from a menu. Maps a whole different access-control mechanism from object-level PUBLIC authority.
- Active Job Scanner - Lists currently active jobs and their users. Run from a menu. A live snapshot of who's actually doing what right now.
- Exit Point & Service Registration Audit - Reads FTP, NetServer, remote-command, and remote-SQL exit-point registration. Run from a menu. An unregistered exit point means no control over that access path at all.
- NetServer / SMB Configuration Audit - Checks the IBM i NetServer configuration for a set guest profile and unsigned SMB. Run from a menu. Either finding hands an attacker a foothold with effectively zero authentication.
- IFS Permission Sweep - Scans the IFS (the Unix-like file-system side of IBM i) for world-writable and world-readable-and-sensitive objects. Run from a menu. Finds a writable shell script or an exposed credential file outside the traditional object space.
- Adopted-Authority Runtime Scanner - Walks the program call stack and flags any program adopting a more privileged owner's authority. Run from a menu. A program adopting QSECOFR is a privilege-escalation path by design, this finds exactly which one.
- Menu/Command-Line Bypass Probe - Drives several "Work with X" screens' command lines directly, exploiting LMTCPB often never actually being enforced there. Run from a menu. Proves a "limited capability" user can run real commands anyway.

z/VM

- VM Minidisk Password Exposure - Shows that a LINK command's minidisk password renders in cleartext at the CP READ prompt, since CP has no masked-input primitive for command arguments. Connect to a z/VM CP session, type a real LINK command with a password. A simple, visual demonstration that CP command-line arguments are never masked.

z/TPF

- ECB Enumerator - Lists every loaded entry control block and its privilege flags. Run at the operator console. A full map of what's running and at what privilege level.
- Privilege Scanner - Probes the OPER, SYSOP, SYSPROG boundary. Run at the operator console. Confirms exactly which privilege tier the current session has, rather than assuming from the logon role.
- Entry Point Prober - Tests every ECB and reports response time, status, and privilege flags. Run at the operator console. Fast triage across every entry point at once.
- Pool Monitor - Flags memory pools above 90% capacity. Run at the operator console. Early warning for a resource-exhaustion condition before it becomes an outage.
- System Diagnostics - Runs a full resource-containment sweep and flags held locks, deferred-queue depth, and high record-type allocation together. Run at the operator console. Frames what would look like four unrelated numbers as one incident.
- Entry Point Debugger - Drives a full attach, breakpoint, step, and storage-read sequence against an entry point. Run at the operator console. Shows, live and safely, that this debugger's privilege check happens once at attach and is never re-verified on a later storage read, a real storage-isolation-failure pattern explained hands-on.
- Hardening Audit - Checks daemon exposure, console-command routing, and demo OS accounts for training-lab-style weaknesses in one sweep. Run at the operator console. One severity-sorted findings table for the "leftover training/demo access" class of finding.

Not a tool: z/TPF deep-internals methodology

Storage-protection-key escalation, core/memory-block corruption, and record-pointer injection are real z/TPF risk categories, but deliberately not shipped as a live tool: a bug in a browser-based probe for any of them risks an outage on what's typically a production airline reservation system. The project's methodology document covers the actual approach instead, source and macro review first, then isolated-lab testing only once review produces a specific hypothesis, and it ties back to the Entry Point Debugger above as a safe, live way to demonstrate the concept.

Everything above runs from one bridge, one browser client, against real TN3270(E)/TN5250 protocol and real EBCDIC, either a live mainframe or the project's own mock LPAR fleet for a zero-risk demo. Project, docs, and source: github.com/wren-creator/web3270.